4. From Aggregate Auditing to Reliable Patient-Level Vulnerability Assessment

Throughout this review, **vulnerability** $V_{p,c}$ denotes an empirical quantity for patient p under audit configuration c, such as a patient-level attack AUC, a worst-record AUC summary, a likelihood-ratio statistic, or TPR at a specified FPR. Each has its own scale and estimand. **Risk** R_p is reserved for an explicitly defined operational decision or a membership posterior probability calibrated under a stated prior, candidate population, and validation design. A high-vulnerability or "high-risk" label based on V is an operational designation, not a probability of harm. Neither an AUC nor a likelihood ratio becomes a calibrated patient-level probability by renaming it.

4.1 Aggregate Auditing: Capabilities and Limitations

Aggregate privacy auditing pools attack scores for member and non-member records and summarizes their separation using a single measure or curve, such as attack accuracy, ROC-AUC, or TPR at a selected FPR. Shokri et al.'s shadow-model framework established a practical black-box form of this audit by generating labeled "in" and "out" examples with shadow models and using them to train an attack classifier [1]. Aggregate summaries remain valuable for system-level screening and for controlled comparisons across target models, attacks, training procedures, and defenses. Their estimand, however, is attack performance for records drawn from the audit population; it is not the exposure of a specified record or patient.

Deployment-relevant interpretation therefore requires explicit operating points. Accuracy depends on the member–non-member balance and the decision threshold, whereas ROC-AUC averages discrimination across all FPRs, including regions that may be unacceptable in practice. Carlini et al. recommend reporting the full ROC curve on logarithmic axes and the TPR at low FPRs, such as 0.1% or 0.001%, to reveal attacks that confidently identify a small subset of members [2]. Such estimates require sufficient non-member observations. If approximately half of M target-model observations for each sample fall under the out hypothesis, at least $2/\alpha$ models are required merely to attain an empirical FPR of α; even at this minimum, the ROC estimate may remain highly uncertain [14]. This is a resolution bound rather than a sufficient-sample recommendation. Likewise, observing no false positives in a small audit does not establish a zero population FPR and should be accompanied by an appropriate binomial confidence bound.

Knolle et al. demonstrated the clinical limitation: aggregate AUC could remain near chance while some patient-linked records were almost perfectly distinguishable across repeated models [3]. Their maximum record-AUC patient summary is descriptive, and a defense that improves the global curve need not benefit those patients.

Pooled scores can also be confounded by intrinsic sample difficulty. An easy non-member may receive high confidence or low loss from many models and consequently resemble a member, whereas a difficult member may not. Watson et al. calibrate a target score against the behavior of reference models trained on data from the same distribution, thereby separating target-model-specific behavior from general predictability and reducing false positives [13]. Per-example reference distributions in likelihood-ratio attacks serve a related purpose [2]. These methods improve the evidential meaning of an attack score, but calibration of a score does not by itself convert a pooled audit into an estimate of individual vulnerability.

Aggregate findings are additionally conditional on population composition and on the membership experiment being implemented. Group prevalence, member and non-member sampling, threshold selection, and randomness in data construction and model training can all change the reported result. Ye et al. show that fixing or randomly drawing the target model, record, surrounding dataset, and training randomness defines different membership games and therefore different leakage quantities [6]. Subgroup estimates add another layer of uncertainty: Kulynych et al. demonstrate that naïve procedures can overstate disparity, particularly for small groups, and propose repeated-measures estimation with statistical testing and multiple-comparison correction [7]. Jälkö et al. further show that concatenating scores across individuals under one global threshold controls only the average per-sample FPR; individual FPRs may vary substantially, and heterogeneity may be suppressed [14].

Because this latter evidence is currently a methodological preprint, it should be treated as an important caution pending peer review.

4.2 Record-Level and Sample-Specific Vulnerability

Moving from aggregate auditing to individual assessment changes both the unit and the meaning of analysis. A membership score for one record against one trained model is a single observation whose interpretation depends on the attack signal, threshold, membership prior, and randomness in data sampling and training. It is therefore insufficient for assigning a stable "high-risk" label. Record-level assessment should instead characterize how distinguishable the model's behavior is when the same record is included in, rather than excluded from, training, using repeated target models or appropriately constructed reference distributions. High vulnerability is consequently defined relative to a specified counterfactual experiment; it is not an intrinsic, attack-independent property of the record.

Song and Mittal introduced an early fine-grained privacy-risk score that formalizes part of this perspective [15]. For a sample z, the score is the posterior probability

$$P(z \in D_{\text{tr}} \mid O(F, z)),$$

after observing the target model's behavior $O(F, z)$ on that sample. By Bayes' rule, the score depends on the prior probability of membership and on the conditional output distributions for members and non-members. Their experiments used equal membership priors and estimated class-conditional distributions from shadow-model outputs on shadow training and test data, with modified entropy as one possible statistic. The analysis revealed substantial heterogeneity and showed that a defense could reduce average estimated posterior scores while increasing them for a small subset of samples. Nevertheless, this is a fine-grained posterior score rather than a fully sample-specific counterfactual distribution: it depends on the membership prior, the selected statistic, and the quality and similarity of the shadow data. The evidence was also obtained primarily from general benchmarks, including a health-related tabular dataset, rather than from patient-level clinical audits.

LiRA advances sample-specific assessment by constructing a separate membership comparison for each target example [2]. Reference models trained with and without a fixed example estimate its "in" and "out" distributions of transformed confidence or loss, and the observation from the target model is evaluated through a likelihood ratio. Unlike a single global threshold, this comparison accounts for variation in baseline difficulty and for the effect of including the particular record. Ye et al. show why the underlying experiment must still be stated: fixing or marginalizing over the target record, model, dataset, and training randomness produces distinct membership games and leakage estimands [6]. Watson et al. address a related confound by calibrating target-model loss against typical reference-model behavior, so that an intrinsically easy non-member is not considered vulnerable solely because the model predicts it confidently [13]. In this sense, sample-specific vulnerability is a counterfactual comparison, not a ranking of uncalibrated raw scores.

Knolle et al. trained 200 models on patient-level subsets and fitted Gaussian IN/OUT distributions of logit-transformed confidence for each record [3]. The resulting bi-normal AUC measures separability across model draws for that record, not a posterior membership probability. A small near-perfect tail persisted despite near-chance aggregate AUC.

Record-level estimates nevertheless remain conditional measurements rather than universal privacy labels. They can change with the attack, observable signal, adversarial access, membership prior, learning algorithm, data-sampling protocol, reference-model construction, number of repetitions, and assumptions imposed on the in and out distributions. Efficient reuse of a finite population of records may also distort the estimated distributions: Jälkö et al. identify a finite-population effect in an efficient LiRA implementation that can underestimate distributional variance and positively bias per-sample vulnerability estimates [14]. These dependencies should be documented before records are compared or classified as highly vulnerable. Moreover, an estimate for one released model addresses exposure under that realization, whereas an estimate averaged across retraining runs addresses vulnerability of the learning procedure. Neither should be silently substituted for the other.

4.3 Patient-Level Membership and Multiple-Record Contributions

Patient-level membership requires redefining the protected event rather than merely relabelling a record-level score. Let $\mathcal{R}_p = \{r_{p1}, \ldots, r_{pm_p}\}$ denote the set of records associated with patient p, and let D denote the training records. An any-contribution game tests

$$H_0 : D \cap \mathcal{R}_p = \emptyset \qquad \text{versus} \qquad H_1 : D \cap \mathcal{R}_p \neq \emptyset.$$

This asks whether the patient contributed at least one training record. It differs from a whole-contribution game,

$$H_0 : D \cap \mathcal{R}_p = \emptyset \qquad \text{versus} \qquad H_1 : \mathcal{R}_p \subseteq D,$$

in which partial-contribution states are excluded by the experimental design. A threshold-contribution game may instead test $H_0 : |D \cap \mathcal{R}_p| < k$ against $H_1 : |D \cap \mathcal{R}_p| \geq k$. These hypotheses protect different secrets and are not interchangeable. Patient-level splitting assigns one membership state to all of a patient's records, whereas record-level splitting permits partial membership and may also leak patient information across training and evaluation partitions.

Redefining the hypothesis changes how record-level evidence can be combined. For one model and one attack score s, the statistic

$$T_p(F) = \max_j s(F, r_{pj})$$

is aligned with the any-contribution threat because one confidently inferred record may reveal the patient's participation. However, the maximum increases with the number of opportunities and may favor patients with more records even when their record-score distributions are identical. A mean represents the vulnerability of a typical record but may conceal a single revealing examination, while majority voting may miss sparse but decisive evidence. Repeated scans, visits, or measurements from one patient are also correlated, so multiplying record-level probabilities or combining tests under independence can produce unjustified confidence. A patient-level statistic therefore needs a prespecified decision rule and a null distribution that reflects record count, within-patient dependence, and the intended membership event.

It is also important to distinguish a within-attack patient statistic from a worst-record audit summary. The quantity $\max_j s(F, r_{pj})$ combines record scores observed for a particular model, whereas

$$\max_j \widehat{\mathrm{AUC}}_{pj}$$

selects the largest estimated record-level AUC across repeated models. The latter describes the patient's most distinguishable record under the audit; it is not automatically the AUC of a joint patient-level attack, nor is it a calibrated probability that the patient was a member. Conflating these quantities can make a descriptive worst-record summary appear to be a formally evaluated patient-level classifier.

Knolle et al. operationalised an any-record interpretation in clinical AI by treating successful inference for any contributed record as sufficient to reveal patient membership and using the maximum record-level MIA AUC as the patient-level summary [3]. Their target models were trained on patient-level subsets, ensuring that all records belonging to a patient shared the same inclusion state. This conservative summary exposed patients with near-perfect record vulnerability that aggregate auditing obscured. It also demonstrates why patient-level sampling matters: the authors report that record-level sampling underestimated MIA success for patients contributing multiple similar records. Nevertheless, their maximum-AUC summary can depend on record multiplicity and does not establish a universally optimal rule for combining patient evidence.

Evidence outside clinical AI further shows why attacks designed directly for a subject-level hypothesis may be preferable to post hoc aggregation. Suri et al. define subject membership by distinguishing training populations that exclude a person from populations containing that person's data, including

settings in which the records are distributed across institutions [16]. Their black-box attacks can use samples from the subject's distribution without requiring the exact records used for training, separating subject privacy from both item-level membership and the privacy of a participating institution. Li et al. similarly ask whether any image from a user trained a metric-embedding model [17]. Their attack exploits the compactness of embeddings from several same-user images and can infer a training user using images that were not themselves training records. These studies show that person-level evidence may arise from shared distributional structure across records. Because neither study evaluates clinical patients, however, they provide methodological support rather than direct estimates of clinical patient vulnerability.

A patient audit must specify the contribution hypothesis and combination rule. More records may change training influence or simply offer more opportunities for an extreme maximum; the relationship is not universally monotonic. Direct patient-level attacks and worst-record summaries should be reported as different estimands.

4.4 Estimating Vulnerability: Uncertainty, Calibration, and Reproducibility

Once the record or patient has been fixed as the unit of analysis, its estimated vulnerability remains a random quantity. Variation can arise from sampling the surrounding dataset, assigning membership, initializing the model, data augmentation, and stochastic optimization. Ye et al. show that fixing or randomly drawing the target record, target model, surrounding dataset, and training randomness defines different membership games and quantities [6]. A measurement obtained from one seed therefore characterizes one model realization; it does not by itself establish stable vulnerability of the learning procedure. Patient-level repetitions must also preserve the declared contribution mechanism: all records should share membership when the game concerns whole-patient inclusion, whereas partial contribution requires a separately specified hypothesis and sampling design.

Precision depends on effectively independent IN and OUT model draws. The clinical design discussed in Section 4.2 used about half of its model draws in each membership state. If half of M draws are OUT, $M \geq 2/\alpha$ gives only the minimum resolution for an empirical FPR α, not a precise estimate [14]. Zero observed false positives still need an upper confidence bound; overlapping finite training pools and correlated patient records reduce effective information.

Calibration has distinct targets: a threshold that controls **patient-level** FPR [14], a score adjusted for intrinsic sample difficulty [13], and a posterior probability validated for an explicit membership prior [15]. Likelihood ratios alone do not prove posterior calibration, and a maximum of calibrated record scores is not automatically calibrated for patients with different record counts. The unit and decision rule must match the claim.

Reproducibility should also be distinguished from robustness. Reproducibility asks whether the same prespecified audit—using the same estimand, attack, sampling design, and analysis procedure—produces compatible conclusions when rerun. Robustness asks whether the conclusion persists under defensible changes to seeds, architectures, training procedures, attack signals, reference data, and adversarial-knowledge assumptions. Failure of robustness does not necessarily invalidate an audit, because different attacks or membership games may estimate different quantities; it instead limits the scope of the resulting claim. Borderline cases whose classification changes within statistical uncertainty should remain indeterminate rather than being forced into binary categories.

Table 4.1 consolidates the reporting requirements for individual and subgroup audits. In particular, an operational high-risk designation needs a patient-calibrated decision rule, uncertainty, and multiplicity-aware inference when many patients or groups are screened [7].

4.5 Identifying Highly Vulnerable Patients Across Models and Attacks

A "high-risk patient" is an **operational category** defined by a threshold on a named vulnerability estimand, not a calibrated probability. An absolute metric-specific threshold, a patient-level TPR at a fixed patient-level FPR, a relative top percentile, and a lower-confidence-bound criterion answer different questions. Knolle et al. described maximum record-level AUC ≥0.95 as near-perfect worst-record separability [3]; it is not the success probability of a calibrated joint patient attack. A top-1%

set exists even when absolute vulnerability is low, and an uncertain boundary case should remain indeterminate [2].

For claims about a learning procedure, recurrence across retraining runs provides stronger evidence than exceedance in one fitted realization. Model-specific exposure remains important for the model actually deployed, but it should not be generalized to other seeds, architectures, capacities, or defenses without repeated evidence. Knolle et al. showed that increasing model capacity could substantially enlarge the extreme-vulnerability tail [3]. This establishes model dependence in the prevalence of exposure, not persistence of the same patient identities across capacities. Cross-institution comparisons are more limited still: unless patient identities are legitimately linkable and the estimand is unchanged, they compare the prevalence or determinants of vulnerability rather than persistence of individual exposure.

Consistency should also be examined across attacks that target the same membership event under comparable access assumptions. Loss-based attacks, LiRA, RMIA, and related procedures can be compared through rank correlations, threshold-exceedance frequencies, and overlap between prespecified patient sets. Disagreement is not automatically measurement error: attacks may exploit different signals or retain different adversarial uncertainties [6]. A union of attack-specific sets is sensitive but increases false-positive designations unless multiplicity is controlled; an intersection is conservative and can omit genuine attack-specific exposure. Neither should be presented as a universal high-risk label.

Comparability becomes more restricted when the audit extends beyond membership inference. MIA AUC, attribute-inference accuracy beyond an auxiliary-information baseline, and inversion or reconstruction error target different secrets and should not be normalized and averaged without a validated decision-theoretic justification [4]. A more defensible representation is a multidimensional profile,

$$\mathbf{V}_p = \left(V_p^{\text{MIA}}, V_p^{\text{attribute}}, V_p^{\text{inversion}}, V_p^{\text{reconstruction}}\right),$$

with the targeted secret, attack access, operating point, attribution to the patient, and uncertainty reported separately for each dimension. Model stealing should remain outside this patient-disclosure profile unless an empirical link to disclosure of patient information is demonstrated.

Evidence strength is best described along two axes: recurrence across prespecified retraining conditions and support across compatible attacks. The strongest claim—recurrent cross-model and cross-attack exposure—requires attacks that target the same secret and membership hypothesis under comparable threat models. These axes characterize robustness, not severity. Calibration must also match the patient-level decision rule. Jälkö et al. show at sample level that a pooled threshold can mask heterogeneous sample-specific FPRs [14]; extending this concern to patient statistics is a methodological implication that still requires direct validation.

A patient selected in one condition should be described as exposed under that condition; persistence requires prespecified repeated evidence. Section 5 applies this distinction to clinical and demographic populations.

Table 4.1. Minimum patient-level privacy evaluation framework

Component	Minimum specification or outcome
Unit	Patient identifier and record count; partition patients consistently within target, test and reference designs, except for deliberate IN/OUT inclusion of the target; retain clusters in inference
Membership hypothesis	Any-, partial-, or whole-contribution event; candidate population and comparable non-members
Attack	Access, observable statistic, auxiliary data, query and model budgets; at least one adapted strong attack plus a complementary feasible attack

Component	Minimum specification or outcome
Calibration	Mechanism-matched reference models; patient-level operating-point FPR and, only for probability claims, posterior validation under a stated prior
Uncertainty	IN/OUT counts, repeated target/reference models, intervals and indeterminate threshold cases; account for patient correlation and multiplicity
Tail metrics	Paired $\widehat{V}_p^{(0)}$, $\widehat{V}_p^{(1)}$, benefit, fixed baseline set, upper percentiles and residual threshold prevalence
Subgroups and sites	Denominators, within-group exposure and tail composition, intersecting groups where powered, site/protocol controls
Clinical utility	Discrimination, subgroup performance, probability calibration and prespecified clinical thresholds
Vulnerability transfer	Paired worsening outside the selected set; separate true increases from tail reordering and estimation noise
Reproducibility	Seeds, model and attack configurations, reference provenance, decision rules, code and compute; independent re-audit after material updates

The table is a reporting protocol, not a claim that all listed measurements are mutually commensurable. Compare before and after on a fixed vulnerability estimand within each compatible attack; keep different secrets or score scales in separate profiles. An operational high-risk rule may be applied to V with a metric-specific threshold and interval, but is not thereby a calibrated membership probability.